Contents

Volume 01 — Essentials, APT/Kill Chain, Firewalls (L01–L09) **1**
L1: Course Introduction & Cyber Security Tool Landscape 1
L2: CIA Triad, Risk Assessment & Security Policies 2
L3: Network Discovery with Nmap & Netcat 2
L4: Packet Analysis with Wireshark 3
L5: APT Lifecycle & Cyber Kill Chain 3
L6: Threat Modeling & Attack Surface Mapping 4
L7: Firewall Concepts — Stateful vs Stateless Filtering 5
L8: Linux Packet Filtering with iptables & UFW 5
L9: Windows Firewall & Host-Based Perimeter Defense 6

Volume 01 — Essentials, APT/Kill Chain, Firewalls (L01–L09)

> Cyber Security Tools · IGNOU/BAOU nou26_ge86 · Prof. Dr. Nilesh K. Modi
> **notes-3** — concept exam notes (what things are / what they do). Condensed from course `pdf/` volumes. No lab command dumps.

Tool landscape, CIA/risk, Nmap/Netcat/Wireshark roles, Kill Chain, STRIDE, firewall concepts.

L1: Course Introduction & Cyber Security Tool Landscape

What it is / what it does

- Security tools are software utilities used to **detect**, **prevent**, **analyze**, or **respond to** cyber threats. This course maps tools to the BAOU PGDCS-103 blocks and hands-on lab workflows.
- **Tool categories:**

Category	Examples	Role
Reconnaissance	Nmap, theHarvester	Discover assets
Scanning	Nikto, OpenVAS	Find vulnerabilities
Exploitation	sqlmap, Hydra	Demonstrate impact (lab only)
Defense	iptables, Snort, Windows Firewall	Block/detect attacks
Analysis	Wireshark, strings	Inspect traffic/files

Defenses (one-liners)

- Maintain asset inventory so unknown scanning is detectable.
- Segment lab networks from production LANs.
- Enforce **authorization** before any security testing.
- Log and monitor VM host activity.

Exam lines

- Security tools are software utilities used to **detect**, **prevent**, **analyze**, or **respond to** cyber threats. This course maps…
- **Tool categories:**

L2: CIA Triad, Risk Assessment & Security Policies

What it is / what it does

- Establish the security foundation before tool usage. Aligns with PGDCS-101 Block 1 and Nina Godbole's risk-management chapters.
- **Confidentiality** — encryption, access control
- **Integrity** — hashing, change detection
- **Availability** — redundancy, backups, DDoS mitigation
- **Policy** — what must be done (e.g., 'All passwords ≥ 12 characters').
- **Procedure** — how to do it (e.g., Active Directory GPO steps).

Defenses (one-liners)

- Publish acceptable-use and password policies.
- Conduct annual risk assessments.
- Map controls to frameworks (ISO 27001, NIST).

Exam lines

- Establish the security foundation before tool usage. Aligns with PGDCS-101 Block 1 and Nina Godbole's risk-management chapters.
- **Confidentiality** — encryption, access control
- **Integrity** — hashing, change detection
- **Availability** — redundancy, backups, DDoS mitigation
- **Policy** — what must be done (e.g., 'All passwords ≥ 12 characters').

L3: Network Discovery with Nmap & Netcat

What it is / what it does

- **Nmap:** Network mapper for host discovery, port scanning, service/version detection, and OS fingerprinting.
- **Netcat:** Swiss-army TCP/UDP tool for connectivity testing, banner grabbing, and simple file transfer.

Defenses (one-liners)

- Deploy IDS/IPS to detect SYN scans (nmap -sS).
- Close unused ports; firewall by default-deny.
- Use port knocking or jump hosts for admin access.

- Rate-limit connection attempts (fail2ban).

Exam lines

- **Nmap:** Network mapper for host discovery, port scanning, service/version detection, and OS fingerprinting.
- **Netcat:** Swiss-army TCP/UDP tool for connectivity testing, banner grabbing, and simple file transfer.

L4: Packet Analysis with Wireshark

What it is / what it does

- Capture and decode network frames to troubleshoot issues and detect malicious traffic.
- **Key display filters:**

Filter	Use
ip.addr == 10.0.0.5	Host traffic
tcp.flags.syn == 1	SYN packets
dns	DNS queries
tls.handshake.type == 1	TLS ClientHello

Defenses (one-liners)

- Encrypt traffic (TLS 1.2+) to limit passive disclosure.
- Monitor for DNS tunneling and unusual protocols.
- Store PCAPs securely with access controls.
- Use encrypted management channels (SSH, not Telnet).

Exam lines

- Capture and decode network frames to troubleshoot issues and detect malicious traffic.
- **Key display filters:**

L5: APT Lifecycle & Cyber Kill Chain

What it is / what it does

- Understand how advanced persistent threats progress through stages — maps offensive tools to defensive detection points.
- **Reconnaissance** — OSINT, Nmap
- **Weaponization** — malware + exploit paired
- **Delivery** — phishing email, drive-by

- **Exploitation** — trigger vulnerability
- **Installation** — persistence, backdoor
- **Command & Control** — beacon to C2 server
- **Actions on Objectives** — data theft, destruction
- **MITRE ATT&CK mapping** — Use ATT&CK Navigator to map techniques (T1595 Recon, T1190 Exploit Public-Facing App) to tools covered in this course.

Defenses (one-liners)

- **Defense in depth** — block multiple stages.
- Email filtering + user awareness (break delivery).
- EDR for installation/C2 detection.
- Network segmentation to limit lateral movement.

Exam lines

- Understand how advanced persistent threats progress through stages
- **Reconnaissance** — OSINT, Nmap
- **Weaponization** — malware + exploit paired
- **Delivery** — phishing email, drive-by
- **MITRE ATT&CK mapping** — Use ATT&CK Navigator to map techniques (T1595 Recon,…

L6: Threat Modeling & Attack Surface Mapping

What it is / what it does

- Systematically identify threats before attackers do; prioritize which tools to deploy for testing.
- **STRIDE model:**

Threat	Example	Tool to test
Spoofing	Fake login page	Phishing sim
Tampering	SQL injection	sqlmap
Repudiation	Log deletion	auditd
Info disclosure	Verbose errors	Nikto
DoS	SYN flood	hping3 (lab)
Elevation	SUID exploit	manual

Defenses (one-liners)

- Reduce attack surface: disable unused services.
- Apply least privilege.
- Re-model after every architecture change.
- Integrate threat modeling into SDLC.

Exam lines

- Systematically identify threats before attackers do; prioritize which tools to deploy for testing.
- **STRIDE model:**

L7: Firewall Concepts — Stateful vs Stateless Filtering

What it is / what it does

- Firewalls enforce access control at network boundaries — foundation for iptables (L8) and Windows Firewall (L9).
- **Packet-filtering** — examines headers (IP, port); stateless.
- **Stateful** — tracks connection state; allows return traffic automatically.
- **Application-layer (proxy)** — inspects HTTP/DNS content.
- **Next-gen (NGFW)** — IPS, app awareness, threat intel.
- **Default deny** — block all, allow explicitly.
- **Least privilege** — minimum ports/services.
- **Document** every rule with owner and expiry.
- Test rules in staging before production.

Defenses (one-liners)

- Place firewalls at trust boundaries (DMZ, internal segments).
- Log denied packets; alert on spikes.
- Combine with IDS (Snort) for deep inspection.
- Review rules quarterly; remove orphans.

Exam lines

- Firewalls enforce access control at network boundaries
- **Packet-filtering** — examines headers (IP, port); stateless.
- **Stateful** — tracks connection state; allows return traffic automatically.
- **Application-layer (proxy)** — inspects HTTP/DNS content.
- **Default deny** — block all, allow explicitly.

L8: Linux Packet Filtering with iptables & UFW

What it is / what it does

- **iptables:** Linux kernel netfilter framework for packet filtering, NAT, and mangling.

Defenses (one-liners)

- Automate rule deployment (Ansible, Puppet).
- Never expose management ports to the internet.
- Test with nmap after rule changes.

- Monitor /var/log/kern.log for DROP entries.

Exam lines

- **iptables:** Linux kernel netfilter framework for packet filtering, NAT, and mangling.

L9: Windows Firewall & Host-Based Perimeter Defense

What it is / what it does

- Windows Defender Firewall provides host-level inbound/outbound filtering on Windows workstations and servers.

Defenses (one-liners)

- Enforce GPO-managed firewall rules in AD environments.
- Combine with Defender ATP/EDR.
- Disable unnecessary services (SMBv1, Telnet).
- Audit rule changes via Windows Event Log (4946, 4947).

Exam lines

- Windows Defender Firewall provides host-level inbound/outbound filtering on Windows workstations and servers.

Contents

Volume 02 — Wireless, Web Scanning, App Inspection (L10–L18) **1**
L10: Wireless Reconnaissance & Monitoring 1
L11: WPA/WPA2 Security Assessment 2
L12: Web Server Scanning with Nikto 2
L13: OWASP ZAP — Installation & Passive Scanning 3
L14: ZAP Active Scanning & Proxy Interception 3
L15: Directory & Content Discovery 3
L16: SQL Injection Fundamentals & Manual Testing 4
L17: Automated SQL Injection with sqlmap 4
L18: Cross-Site Scripting (XSS) & Client-Side Attacks 5

Volume 02 — Wireless, Web Scanning, App Inspection (L10–L18)

> Cyber Security Tools · IGNOU/BAOU nou26_ge86 · Prof. Dr. Nilesh K. Modi
> **notes-3** — concept exam notes (what things are / what they do). Condensed from course `pdf/` volumes. No lab command dumps.

Wi-Fi assessment ideas, Nikto/ZAP/Gobuster roles, SQLi/XSS concepts — no lab command dumps.

L10: Wireless Reconnaissance & Monitoring

What it is / what it does

- Discover Wi-Fi networks, clients, and security configurations using passive and active wireless monitoring.
- **iwconfig / iw** — interface configuration
- **Airodump-ng** — capture 802.11 frames
- **Kismet** — wireless IDS

Defenses (one-liners)

- Use **WPA3** or WPA2-Enterprise (802.1X).
- Hide SSID is not security — rely on strong PSK/passphrase.
- Deploy WIDS (wireless IDS).
- Disable legacy protocols (WEP, WPA-TKIP).

Exam lines

- Discover Wi-Fi networks, clients, and security configurations using passive and active wireless monitoring.
- **iwconfig / iw** — interface configuration
- **Airodump-ng** — capture 802.11 frames
- **Kismet** — wireless IDS

L11: WPA/WPA2 Security Assessment

What it is / what it does

- Assess Wi-Fi authentication strength by capturing handshakes and testing passphrase entropy (authorized lab only).

Defenses (one-liners)

- Use passphrases ≥ 20 random characters.
- Enable **PMF** (802.11w) where supported.
- Rate-limit authentication attempts.
- Monitor for deauth floods (deauth attack detection).

Exam lines

- Assess Wi-Fi authentication strength by capturing handshakes and testing passphrase entropy (authorized lab only).

L12: Web Server Scanning with Nikto

What it is / what it does

- Open-source web server scanner that identifies outdated software, dangerous files, and misconfigurations.
- **Common findings** — Default files (/admin, /phpinfo.php)
- Outdated Apache/IIS versions
- HTTP methods enabled (PUT, TRACE)
- Missing security headers

Defenses (one-liners)

- Remove default pages and sample apps.
- Keep web server patched.
- Disable dangerous HTTP methods.
- Add security headers (CSP, X-Frame-Options).
- Rate-limit scanner traffic at WAF.

Exam lines

- Open-source web server scanner that identifies outdated software, dangerous files, and misconfigurations.
- **Common findings** — Default files (/admin, /phpinfo.php)
- Outdated Apache/IIS versions
- HTTP methods enabled (PUT, TRACE)
- Missing security headers

L13: OWASP ZAP — Installation & Passive Scanning

What it is / what it does

- OWASP Zed Attack Proxy (ZAP) is a free web app security scanner and intercepting proxy.

Defenses (one-liners)

- Fix all passive findings before active testing.
- Set HttpOnly and Secure on session cookies.
- Implement Content-Security-Policy.
- Run ZAP in CI/CD pipeline (baseline scan).

Exam lines

- OWASP Zed Attack Proxy (ZAP) is a free web app security scanner and intercepting proxy.

L14: ZAP Active Scanning & Proxy Interception

What it is / what it does

- Actively probe web apps for injection flaws, XSS, and misconfigurations.

Defenses (one-liners)

- Input validation and parameterized queries.
- WAF with virtual patching.
- Disable verbose error messages in production.
- Scope active scans to authorized URLs only.

Exam lines

- Actively probe web apps for injection flaws, XSS, and misconfigurations.

L15: Directory & Content Discovery

What it is / what it does

- Find hidden directories, backup files, and admin panels not linked in the application.

Defenses (one-liners)

- Remove backup files from web roots.
- Return consistent 404 pages (no size differences).
- Require authentication for admin paths.
- Monitor for enumeration patterns (many 404s from one IP).

Exam lines

- Find hidden directories, backup files, and admin panels not linked in the application.

L16: SQL Injection Fundamentals & Manual Testing

What it is / what it does

- SQL injection (SQLi) inserts malicious SQL via unsanitized input — manual testing confirms exploitability before automation.

Defenses (one-liners)

- **Parameterized queries / prepared statements** (primary fix).
- ORM with bound parameters.
- Least-privilege DB accounts (no FILE/SHUTDOWN).
- WAF as secondary layer; not a substitute for secure coding.

Exam lines

- SQL injection (SQLi) inserts malicious SQL via unsanitized input — manual testing confirms exploitability before automation.

L17: Automated SQL Injection with sqlmap

What it is / what it does

- sqlmap automates detection and exploitation of SQL injection vulnerabilities.
- **Safety** — Use –batch for non-interactive labs.
- Never run against production without written authorization.
- –tamper scripts for WAF evasion (awareness only).

Defenses (one-liners)

- Same as L16: parameterized queries.
- Block sqlmap User-Agent signatures at WAF.
- Monitor for UNION/SELECT patterns in query strings.
- Deploy database activity monitoring (DAM).

Exam lines

- sqlmap automates detection and exploitation of SQL injection vulnerabilities.
- **Safety** — Use –batch for non-interactive labs.
- Never run against production without written authorization.
- –tamper scripts for WAF evasion (awareness only).

L18: Cross-Site Scripting (XSS) & Client-Side Attacks

What it is / what it does

- XSS injects malicious scripts into pages viewed by other users — stored, reflected, and DOM-based variants.

Defenses (one-liners)

- **Output encoding** (HTML, JS, URL context-aware).
- Content-Security-Policy: default-src ‘self’.
- HttpOnly cookies prevent JavaScript access.
- Sanitize HTML with allowlist libraries (DOMPurify).

Exam lines

- XSS injects malicious scripts into pages viewed by other users — stored, reflected, and DOM-based variants.

Contents

Volume 03 — Web Attacks, IDS, Assurance, Malware (L19–L27) **1**
L19: Command Injection, LFI/RFI & Server-Side Attacks 1
L20: Session Management, CSRF & Authentication Flaws 2
L21: Intrusion Detection with Snort 2
L22: IDS Tuning, IPS Mode & Log Analysis 3
L23: Vulnerability Scanning with OpenVAS/GVM 3
L24: CVSS Scoring & Vulnerability Prioritization 4
L25: Security Assurance — Frameworks, Audits & Compliance 4
L26: Malware Taxonomy & Static Analysis 5
L27: Dynamic Malware Analysis & Sandboxing 5

Volume 03 — Web Attacks, IDS, Assurance, Malware (L19–L27)

> Cyber Security Tools · IGNOU/BAOU nou26_ge86 · Prof. Dr. Nilesh K. Modi
> **notes-3** — concept exam notes (what things are / what they do). Condensed from course `pdf/` volumes. No lab command dumps.

Server-side flaws, session/CSRF, Snort/IDS, OpenVAS, CVSS, frameworks, malware analysis roles.

L19: Command Injection, LFI/RFI & Server-Side Attacks

What it is / what it does

- Server-side injection flaws let attackers execute OS commands or include arbitrary files.

Defenses (one-liners)

- Never pass user input to shell (exec, system).
- Use allowlists for file paths.
- Disable allow_url_include in PHP.
- Run web server as low-privilege user; chroot/containers.

Exam lines

- Server-side injection flaws let attackers execute OS commands or include arbitrary files.

L20: Session Management, CSRF & Authentication Flaws

What it is / what it does

- Weak session handling and missing CSRF tokens enable account takeover and unauthorized actions.
- **Testing steps** — Check cookie flags: Secure, HttpOnly, SameSite.
- Test session fixation: login without accepting new session ID.
- CSRF: create HTML form posting to state-changing endpoint.
- Test password reset flow for token predictability.

Defenses (one-liners)

- Generate cryptographically random session IDs.
- Rotate session ID on login.
- Implement CSRF tokens on all state-changing requests.
- Enforce MFA for sensitive operations.
- Set SameSite=Strict or Lax on cookies.

Exam lines

- Weak session handling and missing CSRF tokens enable account takeover and unauthorized actions.
- **Testing steps** — Check cookie flags: Secure, HttpOnly, SameSite.
- Test session fixation: login without accepting new session ID.
- CSRF: create HTML form posting to state-changing endpoint.
- Test password reset flow for token predictability.

L21: Intrusion Detection with Snort

What it is / what it does

- Snort is an open-source network IDS/IPS that matches traffic against rule-based signatures.

Defenses (one-liners)

- Fragmentation, encoding, encryption bypass signature IDS.
- Defenders: combine Snort with anomaly detection, TLS inspection (where legal).
- Keep rules updated: sudo snort-update / PulledPork.
- Tune rules to reduce false positives.

Exam lines

- Snort is an open-source network IDS/IPS that matches traffic against rule-based signatures.

L22: IDS Tuning, IPS Mode & Log Analysis

What it is / what it does

- Operationalize IDS — reduce false positives, enable inline blocking, correlate alerts.
- **Tuning steps** — Baseline normal traffic for 48 hours.
- Suppress noisy rules (e.g., ICMP ping).
- Create custom rules for critical assets.
- Integrate with SIEM (Splunk, ELK, Wazuh).
- Define escalation playbooks per alert category.

Defenses (one-liners)

- Defense: encrypted C2 is hard to signature-detect — use behavioral analytics.
- Regular purple-team exercises to validate detection coverage.
- Document every suppressed rule with justification.

Exam lines

- Operationalize IDS — reduce false positives, enable inline blocking, correlate alerts.
- **Tuning steps** — Baseline normal traffic for 48 hours.
- Suppress noisy rules (e.g., ICMP ping).
- Create custom rules for critical assets.
- Integrate with SIEM (Splunk, ELK, Wazuh).

L23: Vulnerability Scanning with OpenVAS/GVM

What it is / what it does

- OpenVAS (Greenbone Vulnerability Manager) performs authenticated and unauthenticated network vulnerability scans.

Defenses (one-liners)

- Patch or mitigate every Critical/High finding.
- Schedule monthly scans; continuous with Greenbone Enterprise.
- Use credentialed scans for accurate patch status.
- Validate fixes with re-scan.

Exam lines

- OpenVAS (Greenbone Vulnerability Manager) performs authenticated and unauthenticated network vulnerability scans.

L24: CVSS Scoring & Vulnerability Prioritization

What it is / what it does

- Common Vulnerability Scoring System (CVSS) provides standardized severity ratings for triage.
- **Base:** Attack Vector, Complexity, Privileges, User Interaction, Scope, Impact (C/I/A)
- **Temporal:** Exploit maturity, remediation level
- **Environmental:** asset-specific modifiers

Defenses (one-liners)

- Don't chase volume — prioritize by exploitability + asset value.
- Track mean time to remediate (MTTR) by severity.
- Integrate CVSS with ticketing (Jira, ServiceNow).

Exam lines

- Common Vulnerability Scoring System (CVSS) provides standardized severity ratings for triage.
- **Base:** Attack Vector, Complexity, Privileges, User Interaction, Scope, Impact (C/I/A)
- **Temporal:** Exploit maturity, remediation level
- **Environmental:** asset-specific modifiers

L25: Security Assurance — Frameworks, Audits & Compliance

What it is / what it does

- Assurance demonstrates that controls are designed and operating effectively — PGDCS-103 Block 2, Unit 1.
- **Key frameworks:**

Framework	Focus
ISO 27001	ISMS certification
NIST CSF	Identify, Protect, Detect, Respond, Recover
CIS Controls	Prioritized technical safeguards
COBIT	IT governance

Defenses (one-liners)

- Maintain evidence repository (policy version control).
- Automate compliance checks (InSpec, OpenSCAP).
- Annual external audit for certification.
- Reference Nina Godbole Ch. on metrics and frameworks.

Exam lines

- Assurance demonstrates that controls are designed and operating effectively
- **Key frameworks:**

L26: Malware Taxonomy & Static Analysis

What it is / what it does

- Classify malware and examine binaries without execution — PGDCS-103 Block 2, Unit 2.
- **Malware types** — Virus, worm, trojan, ransomware, rootkit, spyware, adware, fileless malware.

Defenses (one-liners)

- Block known hashes at endpoint (EDR).
- Application allowlisting.
- Email attachment sandboxing.
- User awareness — don’t open unknown attachments.

Exam lines

- Classify malware and examine binaries without execution
- **Malware types** — Virus, worm, trojan, ransomware, rootkit, spyware, adware, fileless malware.

L27: Dynamic Malware Analysis & Sandboxing

What it is / what it does

- Execute malware in isolated environment to observe behavior — network callbacks, file changes, registry keys.
- **Cuckoo Sandbox** — automated analysis
- **ANY.RUN** — interactive cloud sandbox
- **Procmon + Wireshark** — manual analysis

Defenses (one-liners)

- Block C2 domains at DNS/firewall (threat intel feeds).
- Behavioral detection (AMS/EDR).
- Network segmentation limits lateral spread.
- Report IOCs to CERT-In for national coordination.

Exam lines

- Execute malware in isolated environment to observe behavior — network callbacks, file changes, registry keys.
- **Cuckoo Sandbox** — automated analysis
- **ANY.RUN** — interactive cloud sandbox
- **Procmon + Wireshark** — manual analysis

Contents

Volume 04 — E-Commerce, Social Engineering, Cyber Law (L28–L36) 1
L28: E-Commerce Security & TLS/SSL Configuration 1
L29: Payment Security, PCI-DSS & Web Hardening 2
L30: Social Engineering Toolkit & Phishing Simulation 2
L31: OSINT & Human-Factor Countermeasures 3
L32: Password Attacks with John the Ripper 3
L33: Network Login Attacks with Hydra & Defense 4
L34: IT Act 2000 & Indian Cyber Law Essentials 4
L35: Digital Evidence, Incident Reporting & CERT-In 5
L36: Course Synthesis — Tool Chain Integration & Assessment 6

Volume 04 — E-Commerce, Social Engineering, Cyber Law (L28–L36)

> Cyber Security Tools · IGNOU/BAOU nou26_ge86 · Prof. Dr. Nilesh K. Modi
> **notes-3** — concept exam notes (what things are / what they do). Condensed from course `pdf/` volumes. No lab command dumps.

TLS/PCI, phishing/OSINT, password attacks conceptually, IT Act/DPDP, CERT-In, course synthesis.

L28: E-Commerce Security & TLS/SSL Configuration

What it is / what it does

- E-commerce depends on transport encryption and secure certificate management — PGDCS-103 Block 2, Unit 3.
- **TLS best practices** — TLS 1.2 minimum; prefer TLS 1.3.
- Strong cipher suites (AEAD: AES-GCM, ChaCha20).
- HSTS header: Strict-Transport-Security:.
- Certificate transparency monitoring.

Defenses (one-liners)

- Auto-renew certs (Let’s Encrypt, cert-manager).
- Disable SSLv3, TLS 1.0/1.1.
- Implement OCSP stapling.
- Monitor for cert expiry (30-day alerts).

Exam lines

- E-commerce depends on transport encryption and secure certificate management
- **TLS best practices** — TLS 1.2 minimum; prefer TLS 1.3.
- Strong cipher suites (AEAD: AES-GCM, ChaCha20).
- HSTS header: Strict-Transport-Security:.

- Certificate transparency monitoring.

L29: Payment Security, PCI-DSS & Web Hardening

What it is / what it does

- PCI-DSS mandates controls for organizations handling cardholder data.
- **PCI-DSS key requirements** — Install and maintain firewall.
- No default passwords.
- Protect stored cardholder data.
- Encrypt transmission.
- Use and update antivirus.
- Develop secure systems.
- Restrict data access.
- Unique IDs for each person.
- Restrict physical access.
- Track and monitor network access.
- Regularly test security.
- Maintain information security policy.

Defenses (one-liners)

- Tokenize card data (use payment gateway — never store PAN).
- SAQ (Self-Assessment Questionnaire) compliance.
- Quarterly ASV scans (OpenVAS qualified).
- Segregate CDE (Cardholder Data Environment).

Exam lines

- PCI-DSS mandates controls for organizations handling cardholder data.
- **PCI-DSS key requirements** — Install and maintain firewall.
- No default passwords.
- Protect stored cardholder data.
- Encrypt transmission.

L30: Social Engineering Toolkit & Phishing Simulation

What it is / what it does

- Social engineering exploits human psychology — PGDCS-103 Block 2, Unit 4. SET automates phishing and payload delivery in labs.

Defenses (one-liners)

- Security awareness training (quarterly).
- Phishing reporting button.

- DMARC/DKIM/SPF for email authentication.
- MFA on all external-facing logins.
- Never punish users who report — encourage reporting.

Exam lines

- Social engineering exploits human psychology

L31: OSINT & Human-Factor Countermeasures

What it is / what it does

- Open-Source Intelligence gathering demonstrates information leakage before technical attacks.
- **Other OSINT sources** — Shodan, Censys — exposed services
- WHOIS / DNS records
- Social media profiles
- Paste sites (breach data)

Defenses (one-liners)

- Minimize public footprint (OPSEC).
- Separate personal and corporate social media.
- Data classification and handling procedures.
- Red-team OSINT exercises to find leaks.
- Privacy settings on all platforms.

Exam lines

- Open-Source Intelligence gathering demonstrates information leakage before technical attacks.
- **Other OSINT sources** — Shodan, Censys — exposed services
- WHOIS / DNS records
- Social media profiles
- Paste sites (breach data)

L32: Password Attacks with John the Ripper

What it is / what it does

- John the Ripper (JtR) cracks password hashes offline — demonstrates why strong hashing matters.

Defenses (one-liners)

- Store passwords with **bcrypt**, **scrypt**, or **Argon2** — never MD5/SHA1.

- Enforce password complexity + length (≥ 12 chars).
- Implement account lockout / rate limiting.
- Deploy MFA everywhere.
- Use password managers.

Exam lines

- John the Ripper (JtR) cracks password hashes offline — demonstrates why strong hashing matters.

L33: Network Login Attacks with Hydra & Defense

What it is / what it does

- THC-Hydra performs parallelized login brute-forcing against network services.

Defenses (one-liners)

- Disable password auth for SSH; use key-based auth.
- CAPTCHA after N failed logins.
- fail2ban / CrowdStrike / WAF rate limiting.
- Monitor authentication logs (auth.log, Event 4625).

Exam lines

- THC-Hydra performs parallelized login brute-forcing against network services.

L34: IT Act 2000 & Indian Cyber Law Essentials

What it is / what it does

- Legal framework governing cybercrime in India — Nina Godbole, *Cyber Security*, legal perspectives chapter.
- **Key IT Act sections:**
- **DPDP Act 2023** — Personal data processing obligations; consent; data principal rights; penalties up to ₹250 crore.

Section	Offence
43	Unauthorized access, damage (civil compensation)
66	Computer-related offences (criminal)
66C	Identity theft
66D	Cheating by personation (phishing)
66E	Violation of privacy (image capture)
66F	Cyber terrorism
67	Publishing obscene material
69	Govt. interception powers

Section	Offence
72	Breach of confidentiality

Defenses (one-liners)

- Maintain lawful interception policies.
- Data Processing Agreements with vendors.
- Incident response aligned with CERT-In reporting.
- Legal review before pentesting contracts.

Exam lines

- Legal framework governing cybercrime in India
- **DPDP Act 2023** — Personal data processing obligations; consent; data principal rights; penalties up to ₹250 crore.
- **Key IT Act sections:**

L35: Digital Evidence, Incident Reporting & CERT-In

What it is / what it does

- Proper evidence handling and timely reporting are legal and operational requirements.
- **Chain of custody** — Identify and isolate affected systems.
- Photograph/document state.
- Hash all acquired images: sha256sum image.dd.
- Log every person who handles evidence.
- Store on write-once media or WORM storage.
- Maintain custody transfer forms.
- **CERT-In reporting (2022 directions)** — Report cyber incidents within **6 hours** for: data breaches, ransomware, DDoS on critical infra, etc.
- Log retention: 180 days minimum.
- NTP synchronization required.

Defenses (one-liners)

- Pre-draft incident response plan (IRP).
- Tabletop exercises quarterly.
- Retainer with legal counsel.
- Preserve logs centrally (SIEM) before attacker deletion.

Exam lines

- Proper evidence handling and timely reporting are legal and operational requirements.
- **Chain of custody** — Identify and isolate affected systems.

- Photograph/document state.
- Hash all acquired images: sha256sum image.dd.
- **CERT-In reporting (2022 directions)** — Report cyber incidents within **6 hours** for: data breaches, ransomware, DDoS on critical…

L36: Course Synthesis — Tool Chain Integration & Assessment

What it is / what it does

- Integrate all tools into an end-to-end assessment workflow — capstone for nou26_ge86.
- **Report template** — Executive summary
- Scope and authorization
- Methodology (tools + versions)
- Findings table (ID, severity, CVSS, evidence, recommendation)
- Conclusion and re-test plan

Exam lines

- Integrate all tools into an end-to-end assessment workflow
- **Report template** — Executive summary
- Scope and authorization
- Methodology (tools + versions)
- Findings table (ID, severity, CVSS, evidence, recommendation)
